

Automated Kill Chain Audit

NetShieldAI™ Full-Spectrum Security Assessment

Comprehensive analysis covering Reconnaissance, Network Mapping, Web Discovery, and Vulnerability Exploitation.

TARGET SCOPE:
testphp.vulnweb.com

REPORT ID:
KC-1767602751

GENERATED:
2026-01-05 14:15:51

Executive Summary

TOTAL FINDINGS
44

HIGH / CRITICAL
7

OPEN PORTS
1

URLS CRAWFORD
29

TRAFFIC ANOMALIES
0

Assessment Verdict: **CRITICAL RISK DETECTED**. Immediate remediation is required for 7 high-impact vulnerabilities.

Phase 1: Reconnaissance & Infrastructure

Detected Technology Stack

Category	Technology
Server	nginx/1.19.0
Language	PHP

Network Surface (Open Ports)

Up

Port	Protocol	Service	Version
80	TCP	http	nginx 1.19.0

Subdomains Found (1)

testphp.vulnweb.com

Phase 2: Vulnerability Analysis

Consolidated findings from Python Native Scanner and OWASP ZAP.

Severity	Vulnerability Type	Evidence / Location
CRITICAL	SSRF Server fetched internal/metadata URL.	Server attempted local connection (Param: pp)
CRITICAL	SQL Injection (Error-Based) Database error messages leaked info.	You have an error in your SQL syntax (Param: cat)
HIGH	ZAP: Cross Site Scripting (Reflected) Cross-site Scripting (XSS) is an attack technique that involves echoing attacker-supplied code...	http://testphp.vulnweb.com/artists.php?artist=%3CscrIpt%3Ealert%281%29%3B%3C%2FscRipt%3E
HIGH	ZAP: SQL Injection SQL injection may be possible....	http://testphp.vulnweb.com/cart.php
HIGH	ZAP: SQL Injection - MySQL SQL injection may be possible....	http://testphp.vulnweb.com/artists.php?artist=%27
HIGH	ZAP: SQL Injection - MySQL (Time Based) SQL injection may be possible....	http://testphp.vulnweb.com/secured/newuser.php
HIGH	Reflected XSS Payload reflected without encoding.	Payload reflected verbatim (Param: pp)
MEDIUM	Clickjacking Risk	Missing X-Frame-Options or CSP frame-ancestors (Param: HTTP Headers)
MEDIUM	ZAP: Absence of Anti-CSRF Tokens No Anti-CSRF tokens were found in a HTML submission form.A cross-site request forgery is an...	http://testphp.vulnweb.com
MEDIUM	ZAP: Content Security Policy (CSP) Header Not Set Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate...	http://testphp.vulnweb.com
MEDIUM	ZAP: Missing Anti-clickjacking Header The response does not protect against 'ClickJacking' attacks. It should include either...	http://testphp.vulnweb.com
MEDIUM	ZAP: XSLT Injection Injection using XSL transformations may be possible, and may allow an attacker to read system...	http://testphp.vulnweb.com/showimage.php?file=%3Cxsl%3Avalue-of+select%3D%22document%28%27http%3A%2F%2Ftestphp.vulnweb.com%3A22%27%29%22%2F%3E
MEDIUM	Clickjacking The application allows itself to be embedded in an iframe. Attackers can overlay invisible...	Missing X-Frame-Options and CSP frame-ancestors headers (Param: HTTP Headers)

Severity	Vulnerability Type	Evidence / Location
MEDIUM	Missing Anti-CSRF Token A state-changing form (POST/PUT) does not appear to have a random CSRF token. Attackers can...	Form to 'search.php?test=query' missing Anti-CSRF token (Param: HTML Form)
MEDIUM	Missing Anti-CSRF Token A state-changing form (POST/PUT) does not appear to have a random CSRF token. Attackers can...	Form to 'cart.php' missing Anti-CSRF token (Param: HTML Form)
LOW	Missing CSP	Content-Security-Policy header is missing (Param: HTTP Headers)
LOW	Server Version Leak	Server Header: nginx/1.19.0 (Param: HTTP Headers)
LOW	ZAP: Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) The web/application server is leaking information via one or more "X-Powered-By" HTTP response...	http://testphp.vulnweb.com
LOW	ZAP: Server Leaks Version Information via "Server" HTTP Response Header Field The web/application server is leaking version information via the "Server" HTTP response header....	http://testphp.vulnweb.com
LOW	ZAP: X-Content-Type-Options Header Missing The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older...	http://testphp.vulnweb.com
LOW	ZAP: ZAP is Out of Date The version of ZAP you are using to test your app is out of date and is no longer being...	http://testphp.vulnweb.com/style.css
LOW	Missing Security Headers Critical security headers (HSTS, X-Content-Type-Options) are missing, exposing the user to SSL...	Missing HSTS (Strict-Transport-Security) (Param: HTTP Headers)
LOW	Missing Security Headers Critical security headers (HSTS, X-Content-Type-Options) are missing, exposing the user to SSL...	Missing X-Content-Type-Options: nosniff (Param: HTTP Headers)
LOW	Potential IDOR The application uses predictable numeric IDs to access resources. If authorization checks are...	Parameter 'pp=12' is numeric and predictable. Test manually for IDOR. (Param: URL Parameter)
LOW	Potential IDOR The application uses predictable numeric IDs to access resources. If authorization checks are...	Parameter 'cat=4' is numeric and predictable. Test manually for IDOR. (Param: URL Parameter)
LOW	Potential IDOR	

Severity	Vulnerability Type	Evidence / Location
	The application uses predictable numeric IDs to access resources. If authorization checks are...	Parameter 'cat=2' is numeric and predictable. Test manually for IDOR. (Param: URL Parameter)
LOW	Potential IDOR The application uses predictable numeric IDs to access resources. If authorization checks are...	Parameter 'artist=2' is numeric and predictable. Test manually for IDOR. (Param: URL Parameter)
LOW	Potential IDOR The application uses predictable numeric IDs to access resources. If authorization checks are...	Parameter 'artist=3' is numeric and predictable. Test manually for IDOR. (Param: URL Parameter)
LOW	Potential IDOR The application uses predictable numeric IDs to access resources. If authorization checks are...	Parameter 'pic=6' is numeric and predictable. Test manually for IDOR. (Param: URL Parameter)
LOW	Potential IDOR The application uses predictable numeric IDs to access resources. If authorization checks are...	Parameter 'pic=5' is numeric and predictable. Test manually for IDOR. (Param: URL Parameter)
LOW	Potential IDOR The application uses predictable numeric IDs to access resources. If authorization checks are...	Parameter 'pic=3' is numeric and predictable. Test manually for IDOR. (Param: URL Parameter)
LOW	Potential IDOR The application uses predictable numeric IDs to access resources. If authorization checks are...	Parameter 'pic=4' is numeric and predictable. Test manually for IDOR. (Param: URL Parameter)
LOW	Potential IDOR The application uses predictable numeric IDs to access resources. If authorization checks are...	Parameter 'pic=1' is numeric and predictable. Test manually for IDOR. (Param: URL Parameter)
LOW	Potential IDOR The application uses predictable numeric IDs to access resources. If authorization checks are...	Parameter 'artist=1' is numeric and predictable. Test manually for IDOR. (Param: URL Parameter)
LOW	Potential IDOR The application uses predictable numeric IDs to access resources. If authorization checks are...	Parameter 'cat=3' is numeric and predictable. Test manually for IDOR. (Param: URL Parameter)
LOW	Potential IDOR The application uses predictable numeric IDs to access resources. If authorization checks are...	Parameter 'cat=1' is numeric and predictable. Test manually for IDOR. (Param: URL Parameter)
LOW	Potential IDOR The application uses predictable numeric IDs to access resources. If authorization checks are...	Parameter 'pic=2' is numeric and predictable. Test manually for IDOR. (Param: URL Parameter)
LOW	Potential IDOR The application uses predictable numeric IDs to access resources. If authorization checks are...	Parameter 'pic=7' is numeric and predictable. Test manually for IDOR. (Param: URL Parameter)
INFO	ZAP: Authentication Request Identified	http://testphp.vulnweb.com/secured/newuser.php

Severity	Vulnerability Type	Evidence / Location
	The given request has been identified as an authentication request. The 'Other Info' field...	
INFO	ZAP: Charset Mismatch (Header Versus Meta Content-Type Charset) This check identifies responses where the HTTP Content-Type header declares a charset different...	http://testphp.vulnweb.com
INFO	ZAP: GET for POST A request that was originally observed as a POST was also accepted as a GET. This issue does not...	http://testphp.vulnweb.com/cart.php
INFO	ZAP: Modern Web Application The application appears to be a modern web application. If you need to explore it automatically...	http://testphp.vulnweb.com/AJAX/index.php
INFO	ZAP: User Agent Fuzzer Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a...	http://testphp.vulnweb.com/AJAX
INFO	ZAP: User Controllable HTML Element Attribute (Potential XSS) This check looks at user-supplied input in query string parameters and POST data to identify...	http://testphp.vulnweb.com/guestbook.php

Appendix A: Discovery Scope (URLs)

Top discovered endpoints. Full list available in JSON export.

```

http://testphp.vulnweb.com/hpp/?pp=12
http://testphp.vulnweb.com/showimage.php?file=./pictures/3.jpg
http://testphp.vulnweb.com/listproducts.php?cat=4
http://testphp.vulnweb.com/showimage.php?file=./pictures/7.jpg
http://testphp.vulnweb.com/listproducts.php?cat=2
http://testphp.vulnweb.com/showimage.php?file=./pictures/4.jpg
http://testphp.vulnweb.com/listproducts.php?artist=2
http://testphp.vulnweb.com/listproducts.php?artist=3
http://testphp.vulnweb.com/showimage.php?file=./pictures/1.jpg
http://testphp.vulnweb.com/product.php?pic=6
http://testphp.vulnweb.com/product.php?pic=5
http://testphp.vulnweb.com/images
http://testphp.vulnweb.com/artists.php?artist=3
http://testphp.vulnweb.com/product.php?pic=3
http://testphp.vulnweb.com/product.php?pic=4
http://testphp.vulnweb.com/showimage.php?file=./pictures/5.jpg
http://testphp.vulnweb.com/product.php?pic=1
http://testphp.vulnweb.com/artists.php?artist=1
http://testphp.vulnweb.com/hpp/params.php?p=valid&pp=12
http://testphp.vulnweb.com/login.php
http://testphp.vulnweb.com/admin
http://testphp.vulnweb.com/showimage.php?file=./pictures/6.jpg
http://testphp.vulnweb.com/showimage.php?file=./pictures/2.jpg
http://testphp.vulnweb.com/artists.php?artist=2

```

```
http://testphp.vulnweb.com/listproducts.php?artist=1  
http://testphp.vulnweb.com/listproducts.php?cat=3  
http://testphp.vulnweb.com/listproducts.php?cat=1  
http://testphp.vulnweb.com/product.php?pic=2  
http://testphp.vulnweb.com/product.php?pic=7
```

Generated by NetShieldAI Reporting Engine • Confidential Security Assessment